

FICHE DE TD 3/3 • DIFFICILE

Informatique • 1re C D E

Sécurité informatique et cybercriminalité

Module 1 : Environnement numérique, sécurité, multimédia et gestion des données

Cette fiche propose des situations complexes mobilisant l'ensemble des notions du chapitre : triade CIA, typologie des attaques, défense en profondeur et gestion des privilèges.

EXERCICE 1 Analyse d'incident de sécurité dans une PME

La société CamData SARL (50 employés, serveur local, site web marchand) subit une série d'incidents sur une semaine :

1. Lundi : Le site web est inaccessible pendant 3 h. Les logs montrent un afflux de 50000 requêtes/s depuis 2000 adresses IP distinctes vers la page de paiement.
 2. Mercredi : La comptable reçoit un courriel semblant provenir du DG (dg@camdata.cm) exigeant un virement urgent de 5e6 FCFA vers un nouveau fournisseur. L'adresse expéditrice affichée est correcte, mais l'en-tête Return-Path pointe vers payroll@unknown-domain.xyz.
 3. Vendredi : Découverte de fichiers .exe inconnus sur le poste de la secrétaire. L'anti-virus (signatures du 15/01) ne détecte rien. Une analyse ultérieure révèle un keylogger exfiltrant des mots de passe vers un serveur C2.
1. Pour chaque incident, identifiez l'atteinte aux piliers de la triade CIA (Confidentialité, Intégrité, Disponibilité) et qualifiez l'acte de cybercriminalité correspondant (vocabulaire du programme).
 2. Analysez l'incident de mercredi : détaillez la technique d'ingénierie sociale utilisée, le rôle de l'en-tête Return-Path et pourquoi la vérification de l'adresse From est insuffisante.
 3. Expliquez pourquoi l'antivirus a échoué vendredi. Proposez deux mesures techniques complémentaires (autres que la mise à jour des signatures) pour détecter ce type de menace.
 4. L'administrateur réseau propose de bloquer les 2000 IP sources de l'attaque de lundi au pare-feu. Critiquez cette approche et proposez une stratégie de mitigation plus robuste au niveau du pare-feu et de l'application web.

EXERCICE 2 Conception d'une politique de sécurité et gestion des privilèges

Vous devez définir la matrice de droits d'accès et les mesures de protection pour le SI d'un lycée (salle informatique, bureau de la scolarité, serveur notes/absences, Wi-Fi élèves).

1. Établissez un tableau de correspondance entre les profils suivants et le niveau de pri-

vilège requis (Super-admin, Admin, Invité, Autre à préciser) : Proviseur, CPE, Professeur principal, Élève délégué, Technicien maintenance externe, Parent d'élève (accès notes en ligne). Justifiez chaque affectation par le principe du moindre privilège.

2. Le technicien externe doit intervenir sur le serveur notes. Décrivez la procédure rigoureuse de création, d'utilisation et de révocation de son compte (durée, complexité mot de passe, journalisation, double authentification).
3. Pour le Wi-Fi élèves (accès Internet seul, pas d'accès LAN interne), détaillez la configuration du pare-feu (règles INPUT, FORWARD, OUTPUT) et du serveur RADIUS pour isoler ce VLAN.
4. Le proviseur exige que « tout soit bloqué par défaut ». Formalisez la règle par défaut (Default Deny) et listez les 5 règles ALLOW minimales (source, destination, port, protocole) pour assurer le service pédagogique (DNS, HTTP/S, NTP, mises à jour OS, impression).

EXERCICE 3 Attaques par mot de passe et défense en profondeur

Un audit révèle que 60% des mots de passe du domaine Active Directory sont craquables en moins de 24h.

1. Comparez les attaques par force brute, dictionnaire, rainbow tables et credential stuffing : complexité algorithmique, prérequis (accès au hash, liste de fuites), et efficacité contre un mot de passe de 12 caractères alphanumériques vs une phrase de passe de 4 mots aléatoires.
2. L'administrateur active une GPO : « Longueur min 12, complexité activée, historique 24, durée max 90 jours, verrouillage 5 essais / 15 min ». Identifiez trois effets de bord négatifs sur la sécurité réelle (comportements utilisateurs, charge helpdesk, surface d'attaque) et proposez une alternative moderne (NIST 800-63B) argumentée.
3. Le hachage stocké est NTLM (non salé, MD4). Expliquez la vulnérabilité critique face aux rainbow tables et aux attaques Pass-the-Hash. Décrivez l'apport technique du salage (bcrypt/Argon2) et du pepper stocké dans un HSM.
4. Au-delà du technique, l'audit montre que le phishing reste le premier vecteur de compromission. Concevez un plan de sensibilisation continue (fréquence, indicateurs de performance, simulation) et expliquez comment l'authentification multifacteur (MFA) résistante au phishing (ex : FIDO2/WebAuthn) brise la chaîne d'attaque même en cas de vol de mot de passe.

EXERCICE 4 Synthèse critique : Antivirus, Pare-feu et Responsabilité

1. « L'antivirus et le pare-feu suffisent à sécuriser un poste de travail. » Discutez cette affirmation en distinguant : détection par signature vs heuristique/EDR, pare-feu étatique vs applicatif (WAF), protection périmétrique vs zéro confiance (Zero Trust).
2. Un élève du lycée (exercice 2) utilise une clé USB infectée (vers `autorun.inf` + payload) sur un poste de la salle info (session « Invité » sans droits admin). Le payload tente d'exploiter une faille locale (CVE-2021-40444) pour élever ses privilèges. Analysez la chaîne de défense : stratégie de restriction logicielle (AppLocker/WDAC), désactivation `Autorun`, durcissement OS (ASLR, DEP, CFG), et rôle de l'antivirus comportemental ici.
3. Citez deux infractions spécifiques de la loi camerounaise sur la cybercriminalité (Loi n°2010/012) applicables aux scénarios des exercices 1 et 3 (accès frauduleux, interception, faux informatique). Qualifiez la responsabilité pénale potentielle de l'administrateur qui n'a pas appliqué le correctif de la CVE connue depuis 6 mois (négligence, complicité?).